

Web Security Checklist and Implementation Guide

OWASP Top 10, authentication security, data protection, GDPR web compliance, and a security testing protocol — defensive guidance for securing your own applications.

Scope of This Guide

This guide describes security risks and how to defend against them on systems you own or are authorized to secure. It does not include exploit code or attack instructions. Any security testing described here, including penetration testing, must only be performed on systems you own or have explicit written authorization to test — testing systems without authorization is illegal in most jurisdictions regardless of intent.

1. OWASP Top 10 (2025) Guide

The OWASP Top 10:2025, released by the OWASP Foundation, is the current standard reference for the most critical web application security risks — the first update since 2021. Two categories are new this edition (Software Supply Chain Failures and Mishandling of Exceptional Conditions), and several others were re-ranked based on updated real-world breach data.

#	Category	What It Is	Key Prevention
A01	Broken Access Control	Users able to act outside their intended permissions, including API authorization failures	Enforce access checks server-side on every request; deny by default; test authorization for every role, not just authentication
A02	Security Misconfiguration	Systems, frameworks, or cloud services set up insecurely by default or left unhardened	Harden default configurations; remove unused features/accounts; automate configuration checks in deployment pipelines
A03	Software Supply Chain Failures	Compromises in how software is built, distributed, or updated, often via third-party dependencies	Maintain a software bill of materials; pin and verify dependency versions; monitor for compromised packages, not just known CVEs
A04	Cryptographic Failures	Weak, missing, or misapplied cryptography exposing sensitive data	Use current, vetted cryptographic libraries; enforce TLS 1.2+ everywhere; never write custom cryptographic algorithms
A05	Injection	Untrusted input interpreted as commands or queries by an interpreter (SQL, OS commands, etc.)	Use parameterized queries/prepared statements exclusively; validate and sanitize all input server-side
A06	Insecure Design	Security flaws built into the architecture itself, not fixable by better implementation alone	Threat-model new features before building them; apply secure design patterns from the start, not retrofitted later
A07	Authentication Failures	Weaknesses allowing attackers to compromise credentials, sessions, or identity	See Section 2 for detailed authentication guidance

#	Category	What It Is	Key Prevention
A08	Software or Data Integrity Failures	Code or data trusted without verifying its integrity, including insecure deserialization and unsigned updates	Verify digital signatures on updates and dependencies; avoid deserializing untrusted data
A09	Security Logging and Alerting Failures	Insufficient logging, or logging without effective alerting, delaying breach detection	Log security-relevant events consistently; ensure logs actually trigger alerts reviewed by a person, not just stored
A10	Mishandling of Exceptional Conditions	Improper error handling, logic errors, or systems failing open under abnormal conditions	Fail closed by default; handle errors explicitly rather than relying on default framework behavior

2. Authentication Security

Area	Recommendation
Password storage	Hash with a modern, purpose-built algorithm (bcrypt, argon2, or scrypt) with a unique salt per password — never store passwords in plaintext or with fast general-purpose hashes (MD5, SHA-1) alone
Password policy	Prioritize length over complexity rules; current guidance favors long passphrases over forced complexity and frequent mandatory rotation, which tends to produce weaker, more predictable passwords in practice
Multi-factor authentication	Offer MFA for all accounts and require it for privileged/admin accounts; prefer authenticator apps or hardware keys over SMS where feasible, since SMS can be intercepted or SIM-swapped
Session management	Use secure, HttpOnly, and SameSite cookie flags; rotate the session identifier on login to prevent session fixation; set a reasonable session timeout
Login attempt protection	Rate-limit and progressively delay repeated failed login attempts; lock accounts temporarily after repeated failures without revealing whether the username or password was wrong
Credential recovery	Use time-limited, single-use tokens sent to a verified channel; never email a password directly or reveal whether an account exists during the recovery flow

3. Data Protection Checklist

Item	Why It Matters
All traffic served over HTTPS (TLS 1.2 or higher)	Protects data in transit from interception; a baseline requirement, not an advanced measure
Sensitive data encrypted at rest	Limits exposure if underlying storage is ever compromised or improperly accessed
Data collection minimized to what's actually needed	Data you don't collect can't be breached — the strongest protection is often simply not holding the data
Sensitive data excluded from application logs	Logs are often less tightly access-controlled than primary data stores, and persist longer than expected
Encryption keys managed separately from encrypted data	Prevents a single compromised location from exposing both the data and the means to decrypt it
Backups encrypted and access-restricted	Backups are a common, often-overlooked target — they frequently receive less security attention than production systems
A defined data retention and deletion policy exists and is enforced	Indefinitely retained data is indefinitely at risk; deletion policies reduce exposure over time

4. GDPR Web Compliance

This section is general informational guidance, not legal advice. GDPR compliance depends on your specific data processing activities, and enforcement interpretation continues to evolve. Consult a qualified privacy professional or attorney to confirm compliance for your actual website and business.

Area	General Requirement
Lawful basis for processing	Identify and document a lawful basis (e.g. consent, legitimate interest, contract) for each category of personal data you process
Cookie and tracking consent	Obtain clear, specific, opt-in consent before setting non-essential cookies or tracking scripts; avoid pre-ticked consent boxes
Privacy policy transparency	Clearly state what data is collected, why, how long it's retained, and which third parties receive it
Data subject rights	Provide a real, working mechanism for individuals to access, correct, export, or delete their personal data
Third-party processors	Have a data processing agreement in place with any third party that processes personal data on your behalf (analytics, hosting, email tools)
Breach notification readiness	Have a documented process for identifying and reporting a qualifying data breach within the required timeframe

5. Security Testing Protocol

Different testing types catch different classes of issues — relying on only one leaves real gaps.

Test Type	What It Catches	Typical Cadence
Static Application Security Testing (SAST)	Vulnerable patterns in source code, without running the application	Every commit or pull request, automated
Software Composition Analysis (dependency scanning)	Known vulnerabilities in third-party libraries and packages	Every build, plus continuous monitoring for newly disclosed vulnerabilities
Dynamic Application Security Testing (DAST)	Vulnerabilities visible only in a running application, from an external perspective	Before each release, or on a regular scheduled cadence
Manual code review	Logic flaws and design issues that automated tools typically miss	For security-sensitive changes (authentication, access control, payment handling)
Penetration testing	Real-world exploitability of vulnerabilities, chained together the way an attacker might	Annually, and after major architectural changes — conducted only by qualified professionals with explicit written authorization

Before Any Penetration Test

- Confirm written authorization explicitly scoping what may be tested, by whom, and during what window
- Never test third-party services, infrastructure, or systems outside your explicit authorization, even if they're integrated with your application
- Have an incident response contact on standby during testing, in case the test itself triggers a real alert or unexpected impact